1. Microsoft Threat Modeling

Roll No: 231901005

Aim

To identify potential security threats and vulnerabilities in a given application scenario using Microsoft Threat Modeling Tool, and to recommend appropriate security controls.

Application Scenario

A web-based file sharing application allows a user to log in and upload files over the internet. The web application forwards requests to a backend API, which reads and writes user account data in a User Database and saves uploaded files in File Storage. The internet-facing side and the internal data layer are separated by trust boundaries.

Tools Required

- Microsoft Threat Modeling Tool (version 7.x or later)
- Windows operating system
- Standard (Generic) STRIDE template

Procedure

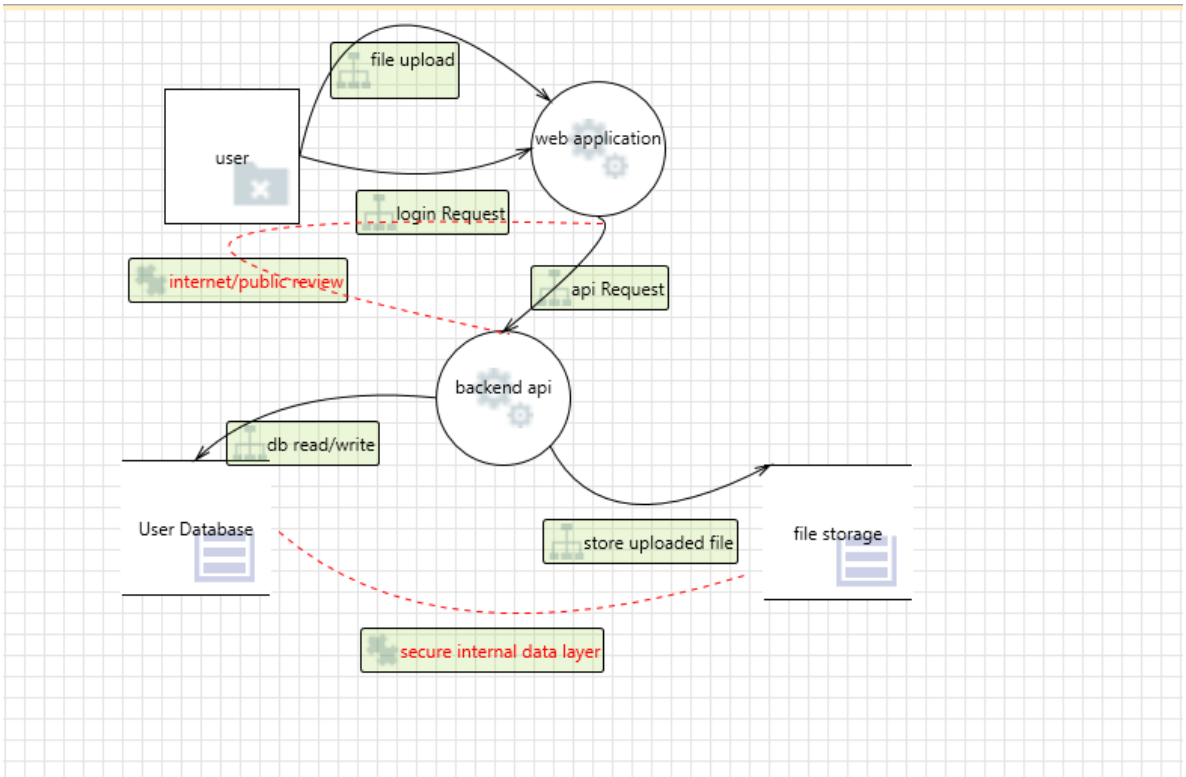
1. Install and open Microsoft Threat Modeling Tool.
2. Create a new threat model.
3. Define the application scenario and its components.
4. Identify external entities, processes, data stores, data flows and trust boundaries.
5. Draw the Data Flow Diagram (DFD) for the given scenario.
6. Define the properties of data flows and components (protocol, authentication, encryption, etc.).
7. Run the threat-generation/analysis feature.
8. Review the threats identified using the STRIDE methodology: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service and Elevation of Privilege.
9. Analyze each identified threat and assign appropriate mitigation controls.
10. Generate and save the threat model report.

DFD Elements Identified

Element Type	Name	Description
External Entity	User	Person who logs in and uploads files from the internet
Process	Web Application	Front end that accepts login and file upload requests
Process	Backend API	Business logic; handles API requests, database and storage access
Data Store	User Database	Stores user credentials and account data
Data Store	File Storage	Stores files uploaded by users

Element Type	Name	Description
Data Flow	Login Request, File Upload, API Request, DB Read/Write, Store Uploaded File	Data moving between the elements above
Trust Boundary	Internet / Public Zone; Secure Internal Data Layer	Separates untrusted users from internal services and data

Output



Data Flow Diagram with trust boundaries

Threats Identified (STRIDE) and Mitigations

STRIDE	Affected Element / Flow	Threat	Mitigation
Spoofing	User -> Web Application (Login Request)	Attacker impersonates a user using stolen or guessed credentials	Multi-factor authentication, strong password policy, account lockout, secure session tokens
Tampering	File Upload; API Request	Malicious or modified files and parameters injected in transit or at input	TLS/HTTPS, input validation, file type and size checks, antivirus scanning, request signing
Repudiation	Backend API	User denies performing an upload or change; no proof available	Secure audit logging with timestamps and user IDs, log integrity protection
Information Disclosure	User Database; File Storage	Leak of credentials or private files through SQL injection or misconfigured access	Encryption at rest and in transit, password hashing with salt, parameterized queries, least-privilege access

STRIDE	Affected Element / Flow	Threat	Mitigation
Denial of Service	Web Application; Backend API	Request flooding or very large uploads exhaust resources	Rate limiting, upload size limits, load balancing, WAF, monitoring and autoscaling
Elevation of Privilege	Backend API -> Database / Storage	Normal user gains admin rights or reaches data of other users	Role-based access control, server-side authorization checks, least privilege for service accounts

Security Controls Summary

- Encrypt all traffic crossing trust boundaries (TLS 1.2 or higher).
- Authenticate and authorize every request at the backend, never only at the front end.
- Keep the database and file storage in a private network, reachable only from the Backend API.
- Log and monitor security events; review the threat model whenever the design changes.

Result

The given application scenario was successfully modeled, potential STRIDE-based threats were identified, and suitable security mitigations were recommended.